

PhishGuard — Technical Reference

Comprehensive catalogue of the **languages, frameworks, libraries, methodologies, techniques, metrics, formulas, factors, and configuration** used by the PhishGuard system.

Repository root: BnB/ · Application: phishguard/

Table of contents

1. [System overview](#)
 2. [Languages & runtimes](#)
 3. [Frameworks & platforms](#)
 4. [Libraries & dependencies](#)
 5. [Architecture & components](#)
 6. [Methodologies](#)
 7. [Techniques by module](#)
 8. [Feature families](#)
 9. [Formulas & algorithms](#)
 10. [Metrics](#)
 11. [Decision factors & policies](#)
 12. [Evaluation protocol](#)
 13. [Security & safety properties](#)
 14. [Testing](#)
 15. [Glossary](#)
-

1. System overview

PhishGuard is a **real-time, fully local, CPU-only, deterministic** phishing-detection system. It monitors one or more IMAP mailboxes, analyses every incoming message with a modular multi-signal pipeline, fuses the signals into an explainable verdict, and takes actions (quarantine / flag / review). It is deliberately built **without any generative LLM** — every decision is statistical, rule-based, or produced by small discriminative models.

Decision levels: **ALLOW** → **FLAG** → **REVIEW** → **BLOCK**.

2. Languages & runtimes

Language / format	Where used
Python 3.11	Backend, detection pipeline, watcher, APIs, scripts, tests (container image <code>python:3.11-slim</code>)
JavaScript (ES modules) / JSX	React dashboard (<code>dashboard/src</code>)
HTML / CSS	Dashboard markup, Mongo webmail test page
YAML	<code>docker-compose.yml</code> , <code>config/policy.yaml</code>
Bash / POSIX sh	<code>scripts/setup_demo.sh</code> , <code>scripts/docker_logger.sh</code> , container entrypoints
SQL (SQLite)	Events, verdicts, audit log, behavioral profiles
MongoDB query / aggregation (BSON)	Shared multi-tester database
Dockerfile syntax	<code>Dockerfile.backend</code> , <code>Dockerfile.dashboard</code> , <code>Dockerfile.logger</code>
MIME / RFC 5322, RFC 7208 (SPF), RFC 6376 (DKIM), RFC 7489 (DMARC)	Email parsing & authentication

3. Frameworks & platforms

Framework / platform	Role
FastAPI	HTTP API server
Uvicorn	ASGI server (hot-reload in dev)
Pydantic v2 / pydantic-settings	Typed models, validation, config loading
React 19	Dashboard UI
Vite 8	Dashboard dev server / bundler
Tailwind CSS v4	Dashboard styling (<code>@tailwindcss/postcss</code>)
pytest	Test framework (backend)
Docker / Docker Compose	Container orchestration (mailserver, roundcube, backend, dashboard, logger)
docker-mailserver	Postfix + Dovecot test mail server
Roundcube	Webmail client
SQLite (aiosqlite / sqlite3)	Local persistence
MongoDB Atlas	Optional shared multi-tester database

4. Libraries & dependencies

Backend / API (requirements.txt)

Library	Purpose
fastapi, uvicorn	HTTP API + ASGI server
pydantic, pydantic-settings	Typed models & settings
imapclient	IMAP IDLE mailbox monitoring
mail-parser	Robust MIME parsing (with a <code>stdlib email</code> fallback)
beautifulsoup4	Static HTML parsing
aiosqlite	Async SQLite
pyyaml	Policy configuration
structlog	Structured JSON logging
networkx	Heterogeneous relationship graph
transformers, onnxruntime, optimum*	ONNX transformer inference (DistilBERT phishing classifier, SecureBERT embeddings)
lightgbm	Gradient-boosted models (URL classifier, fusion meta-model)
shap	Feature-attribution explanations
rapidocr-onnxruntime	OCR of image-borne text
pyzbar (+ Pillow)	QR-code decoding
confusables	Homoglyph/confusable mapping
datasketch	MinHash/LSH near-duplicate detection
python-louvain	Community detection for campaign clustering
scikit-learn	Calibration, metrics, classical models
pandas, pyarrow	Dataset processing / Parquet
olefile	Legacy Office (OLE) static inspection
pypdf	PDF static inspection
idna	Punycode/IDN canonicalisation
Levenshtein	Edit-distance lookalike scoring
xxhash	Fast deterministic hashing
pymongo	Shared MongoDB tracking/messaging (optional)
pytest, pytest-asyncio	Testing

* optimum is installed on demand by the model-export script.

Dashboard (dashboard/package.json)

Package	Purpose
react, react-dom	UI runtime
vite, @vitejs/plugin-react	Build tooling
tailwindcss, @tailwindcss/postcss, autoprefixer, postcss	Styling pipeline (Tailwind v4)
oxlint	Linting

5. Architecture & components

Component	Path	Responsibility
IMAP watcher	guard/watcher/ imap_watcher.py	IDLE monitoring, reconnect backoff, UID tracking, actions (quarantine/flag/review)
Parser	guard/parse/parser.py	MIME → ParsedEmail; recipients, timestamps, URLs (href + display text), capped attachment payloads; stdlib fallback
Normalizer	guard/parse/ normalizer.py	NFKC, zero-width/bidi stripping, single-pass homoglyph folding, URL de-obfuscation
HTML sanitiser / OCR	guard/parse/ html_sanitizer.py, guard/parse/ocr.py	Visible-text extraction; lazy OCR + QR
Header rules	guard/headers/ rules.py	SPF/DKIM/DMARC + header alignment features
NLP	guard/nlp/	Text classifier, tactic classifier, intent features, deterministic embeddings
URL	guard/url/	Lexical features, lookalike, feeds, sandboxed redirect expansion
HTML analysis	guard/html/	Structural/obfuscation/form/JS-static features
Attachment analysis	guard/attachment/	Magic bytes, archives, Office, PDF, SVG (never executed)
Cross-modal consistency	guard/multimodal/	12 contradiction features
Behavioral profiling	guard/behavioral/	Sender/relationship profiles + 12 anomaly features (SQLite)

Component	Path	Responsibility
Graph / campaigns	guard/store/graph.py, planned guard/graph/	Relationship graph, temporal features, clustering
Evidence	guard/evidence/	Typed evidence + deterministic ranking
Fusion	guard/fusion/	Component registry, calibration, uncertainty, decision levels
Explainer	guard/explainer/	Deterministic, evidence-driven explanations
Tracking	guard/tracking/	Optional MongoDB shared store, credentials, backend
Component contract	guard/component.py	AnalysisComponent protocol, safe_run isolation, latency
Pipeline assembly	guard/pipeline.py	Registers all components
Store	guard/store/	SQLite events/verdicts/audit (composite (mailbox, uid) key)
API routes	guard/api/routes/	sessions, events, mailbox (Mongo)

6. Methodologies

1. **Defense-in-depth multi-signal fusion** — no single signal decides; independent evidence families are combined.
2. **Deterministic-first / no generative AI** — classical statistics, rules, graph algorithms, and small discriminative/pretrained encoders only; no LLM, no prompt-based classifier.
3. **Explainability by construction** — every detector emits typed Evidence; the explainer ranks evidence and never invents facts.
4. **Behavioral & contextual analysis** — decisions are contextualised by sender/domain reputation, authentication outcomes, intent, and historical behavior.
5. **Robust anomaly detection** — median/MAD and quantile statistics instead of hard-coded thresholds where practical.
6. **Anti-evasion normalization** — Unicode, zero-width, bidi, homoglyph, and URL obfuscation handling.
7. **Cross-modal consistency** — contradictions across representations of the same email raise independent features.
8. **Graph-based campaign analysis** — relationship graph, temporal edges, near-

duplicate clustering.

9. **Calibrated uncertainty** — calibrated probabilities + component-agreement estimate; a dedicated REVIEW level for high-risk/high-uncertainty mail.
 10. **Cost-sensitive thresholding** — thresholds chosen by configured FP/FN costs, not F1 alone.
 11. **Fail-safe isolation & graceful degradation** — each component runs under `safe_run` with a deterministic fallback; the pipeline never stops because of one dependency.
 12. **Evidence provenance & poisoning prevention** — profiles/graph are updated only after a verdict and only per policy; blocked mail never trains the profiles.
-

7. Techniques by module

Email parsing & normalization

- MIME walk, RFC 2047 header decoding, Reply-To/Return-Path/Received extraction.
- Authentication-Results parsing for SPF/DKIM/DMARC.
- NFKC normalization; removal of zero-width (U+200B/C/D, U+FEFF, U+2060, soft hyphen) and bidi control characters (U+202A–E, U+2066–69).
- **Single-pass confusable folding** (avoids the combinatorial explosion of naive all-combinations normalization).
- URL de-obfuscation: `hxxp→http`, `[.]/(. )→.`, percent-decoding, punycode detection.

Text / NLP

- ONNX DistilBERT phishing classification (deterministic keyword fallback when absent).
- Multi-label-like **tactic classification** (urgency, authority, credential_request, financial).
- **Canonical tactic mapping** (urgency, authority_impersonation, credential_request, payment_gift_card, link_bait, attachment_lure).
- **Derived intent scores** via conjunction rules of tactics × verified technical signals.
- Deterministic feature-hash embeddings (bag-of-tokens, L2-normalised).

URL

- Lexical features (length, entropy, digit ratio, subdomain depth, TLD risk, @, punycode, keyword/brand tokens).
- Lookalike scoring: Levenshtein + confusable distance + domain-token similarity.
- Threat-feed lookups; sandboxed redirect expansion (no JS, capped size/time, SSRF guards).

Header / authentication

- SPF/DKIM/DMARC result features; From ↔ Return-Path ↔ Reply-To domain alignment; display-name impersonation.

HTML (static — JavaScript never executed)

- Structural counts (forms, inputs, password inputs, iframes, scripts, anchors, nodes, depth...).
- Form analysis (external action domains, password forms, iframe credential collection).
- Obfuscation (CSS hiding, transparent/zero-size/offscreen elements, hidden text, redirects).
- JavaScript static indicators (entropy, suspicious tokens, hex/unicode escapes, base64 blobs).
- **Contextualisation**: complexity alone is never risk; raw features are fused with context.

Attachment (static — never executed)

- Magic-byte validation (ignores MIME/extension claims).
- Recursive archive inspection with **decompression-bomb protection** (depth/file/size/ratio).
- Office (OOXML relationships, VBA macros; OLE marker scan), PDF (/URI, /JavaScript, /OpenAction, /Launch, /AcroForm), SVG/HTML script & external-reference detection.
- Byte entropy, filename risk, hash reputation, size anomaly.

Cross-modal consistency

- Display-text vs href, Reply-To vs From, brand vs domain, OCR/QR vs text, subject vs body, attachment vs context.
- Brand dictionary with punycode/Unicode canonicalisation; edit/confusable/token similarity; exact-legitimate vs lookalike distinction; legitimate-mailing-domain allow-list.

Behavioral profiling

- Per-sender and per-(sender,recipient) profiles: frequency, intervals, length, URL/attachment behavior, subject vocabulary, auth outcomes, display-name consistency, historical domains.
- Circular time statistics (sent-hour mean, angular distance), weekday concentration.
- Novelty/frequency for categorical features; robust z-scores for numeric ones.
- Explicit **unknown** / **unusual** / **strongly-anomalous** tri-state (an unknown sender is never classified as phishing).

Graph & campaigns

- Heterogeneous node types (Email, SenderAddress/Domain, ReplyToDomain, URL/URLDomain, IP, ASN, Brand, AttachmentHash, Recipient, Campaign...).
- Timestamped edges → temporal features (ages, velocities, burstiness, churn, growth).

- Campaign similarity channels: MinHash, character n-grams, URL-domain, attachment-hash, sender/infra, subject, embedding similarity.

Fusion, uncertainty & explanation

- Component registry; per-component `safe_run` + latency.
- Calibrated probability; component-agreement uncertainty; decision margin.
- Deterministic evidence ranking; explanation templates.

Shared tracking (optional)

- MongoDB-backed users, messages, `test_events`, `test_feedback`.
- PBKDF2 password hashing; credential auto-detection from `creds/atlas-credentials.env`.

8. Feature families

Family	Count	Examples
Header/auth	6	spf_fail, dkim_fail, dmarc_fail, from_return_mismatch, from_reply_mismatch, display_name_suspicious
Text	1	p_text
Tactic	6 + 6	tactics + derived intent scores
Behavioral	12	sender_newness_score, sender_frequency_anomaly, sender_time_anomaly, sender_domain_change_score, sender_replyto_anomaly, sender_url_behavior_anomaly, sender_attachment_anomaly, sender_authentication_anomaly, recipient_relationship_newness, recipient_relationship_anomaly, display_name_history_

Family	Count	Examples
		anomaly, communication_pattern_anomaly
Cross-modal	12	display_href_mismatch, display_domain_mismatch, sender_identity_mismatch, replyto_identity_mismatch, brand_domain_mismatch, text_url_semantic_mismatch, ocr_url_mismatch, qr_context_mismatch, subject_body_mismatch, attachment_context_mismatch, brand_visual_domain_mismatch, identity_history_mismatch
HTML	~28	form_count, password_input_count, hidden_text_count, suspicious_javascript_tokens, dom_depth, ...
Attachment	15	filename_risk, extension_mismatch, mime_magic_mismatch, file_entropy, archive_depth, nested_archive_count, embedded_url_count, macro_indicator, external_relationship_count, script_indicator, suspicious_pdf_action, attachment_hash_reputation, ...
Graph/temporal	16	domain_age_in_system, sender_burstiness, campaign_growth_rate, shared_infrastructure_count, ...

Family	Count	Examples
Fusion	6	calibrated_probabilit y, uncertainty_score, prediction_confidence, decision_margin, component_agreement, component_disagreemen t

9. Formulas & algorithms

Robust statistics

- Median: middle value of the sorted sample.
- MAD: $\text{MAD} = \text{median}(|x_i - \text{median}(x)|)$.
- Robust z-score: $z = 0.6745 \cdot (x - \text{median}) / \text{MAD}$ (falls back to $0.1 \cdot |\text{median}|$ scale if $\text{MAD} \approx 0$).
- $z \rightarrow \text{score}$: $\text{score} = \min(1, |z| / \tau)$, with $\tau = \text{anomaly_z_threshold}$ (default 3.5).

Circular time (sending hour)

- Mean direction: $\theta = \text{atan2}(\sum \sin(2\pi \cdot h/24), \sum \cos(2\pi \cdot h/24))$, $\text{hour} = (\theta \cdot 12/\pi) \bmod 24$.
- Angular distance: $d = \min(|h_1 - h_2| \bmod 24, 24 - (|h_1 - h_2| \bmod 24))$; $\text{anomaly} = d / 12$.

Categorical novelty / newness

- Novelty: $\text{novelty}(\text{key}) = 1 - \text{count}(\text{key}) / \text{total}$ (1.0 if unseen).
- Newness: $\text{newness} = 1 / (1 + N/5)$ where N = historical messages.
- Relationship newness: $1 / (1 + N/3)$.

Set similarity

- Jaccard: $J(A, B) = |A \cap B| / |A \cup B|$.
- Containment (asymmetric, for subject/filename): $C(A, B) = |A \cap B| / |A|$.

String / brand similarity

- Levenshtein edit distance; confusable distance = edit distance after confusable folding.
- Token similarity = `difflib.SequenceMatcher(a,b).ratio()`.
- Lookalike if `non-identical` and `edit ≤ 2`, or `confusable ≤ 1`, or `brand_token ⊂ domain`.

Entropy

- Shannon: $H = - \sum p_i \log_2 p_i$ (bits); normalised byte entropy = $H / 8 \in [0,1]$.

Obfuscation / bombs

- Archive bomb if $\text{file_size} / \text{compress_size} > \text{max_compression_ratio}$ (or limits exceeded).

Fusion (deterministic fallback)

- Raw score: $\text{score} = p_{\text{text}} + 0.1 \cdot [\text{headers_anomaly_count} > 0]$.
- Calibrated probability (placeholder identity until an isotonic artifact exists): $p = \text{clamp}(\text{score})$.

Uncertainty

- Disagreement: $d = \text{clamp}(2 \cdot \text{MAD}(\text{component_scores}))$.
- Missing ratio: $m = (\text{\#missing components}) / 8$.
- Margin: $\text{margin} = \text{clamp}(|p - 0.5| \cdot 2)$.
- Uncertainty: $u = \text{clamp}(0.70 \cdot d + 0.20 \cdot m + 0.10 \cdot (1 - \text{margin}))$.
- Confidence: $\text{conf} = \text{clamp}(\max(p, 1-p) \cdot (1 - 0.5 \cdot u))$.
- Agreement: $\text{agreement} = 1 - d$.

Decision rule

```
if p ≥ block_threshold:
    level = REVIEW if u ≥ uncertainty_gate else BLOCK
elif p ≥ review_threshold and u ≥ uncertainty_gate:
    level = REVIEW
elif p ≥ flag_threshold:
    level = FLAG
else:
    level = ALLOW
```

Cost-sensitive thresholding (calibration pipeline)

- Objective: $\text{cost} = \text{FP} \cdot C_{\text{fp}} + \text{FN} \cdot C_{\text{fn}} (+ C_{\text{block}}, C_{\text{review}})$, thresholds chosen to minimise cost subject to reported metrics; precision@recall and recall@precision also reported.

Campaign membership — weighted combination of independent similarity channels with a minimum-channel gate: $\text{membership} = \sum w_i \cdot s_i$ and requires $\geq k$ channels above threshold.

10. Metrics

Category	Metrics
Classification	Precision, Recall, F1, PR-AUC, ROC-AUC

Category	Metrics
Error rates	False-positive rate (FPR), False-negative rate (FNR), FPR@95% recall
Per-level	BLOCK_false_positive_rate, FLAG_false_positive_rate, REVIEW FP rate
Threshold curves	Precision@recall, Recall@precision
Robustness	detection_rate, false_negative_rate, score_shift, confidence_shift, robustness_drop (adversarial)
Latency	median (p50) and p95 per stage and end-to-end (target < 500 ms fast path)
Data quality	duplicate/near-duplicate counts, cross-split leakage counts, class/source/time distributions
Uncertainty	uncertainty_score, component_agreement/disagreement, decision_margin

11. Decision factors & policies

Factors that influence a verdict

- Text/tactic/intent signals, URL reputation & lexical risk, authentication results, HTML/obfuscation/form risk, attachment risk, behavioral anomaly, cross-modal contradictions, graph/campaign context, and calibrated uncertainty.
- Contextualisation inputs:** sender/domain reputation, authentication, intent scores, behavioral profile, URL features.

Configuration (config/policy.yaml)

Group	Key knobs
thresholds	block, flag, gray_zone_low, single_component_max
fusion	review_threshold, uncertainty_review_gate
behavioral	update_policy (always/only_below_block/confirmed_only), anomaly_z_threshold, min_observations_before_anomaly
html	max_dom_nodes, max_html_bytes, max_scripts

Group	Key knobs
attachment	max_depth, max_files_per_archive, max_total_uncompressed_bytes, max_compression_ratio, max_attachment_bytes
graph	campaign promotion/membership thresholds, similarity weights
calibration	false_positive_cost, false_negative_cost, block_cost, review_cost, leakage_tolerance
brands	per-brand legitimate_domains; legitimate_mailing_domains
explainer	max_reasons, escalation_min_signals, confidence_threshold

Environment (.env / creds/atlas-credentials.env)

- WATCH_MAILBOXES, DOVECOT_HOST, SQLITE_PATH, model IDs.
- MONGODB_URI/MONGO_URL/MONGO_USER/MONGO_PASSWORD, MONGODB_DB, TESTER_ID.

Guardrails

- Single-component signals cannot reach BLOCK alone (single_component_max: FLAG).
- Unknown senders are never auto-classified as phishing.
- Blocked mail never updates behavioral profiles (poisoning prevention).
- Graph reputation requires confidence/human confirmation before promotion.

12. Evaluation protocol

- **Configurations A–K:** header rules → text → +URL → +headers → +HTML → +behavioral → +cross-modal → +attachments → +graph → +campaigns → full.
 - **Test settings:** random stratified, source-held-out, adversarial, time-based.
 - **Campaign-aware splitting** by group_id (normalize → canonicalize → MinHash → n-gram → attachment hashes → duplicate/campaign groups) with a leakage report that fails the build on cross-split duplicates.
 - **No tuning on the final test set;** thresholds calibrated on a validation split only.
-

13. Security & safety properties

- **No generative AI** — no LLM, chatbot, autonomous agent, or prompt-based classifier.
 - **Email content is untrusted data**, never instructions.
 - **JavaScript is never executed**; HTML is parsed statically.
 - **Attachments are never executed**; archives inspected under depth/size/ratio limits.
 - **Deterministic fallbacks** for every optional dependency (ONNX, OCR, mailparser, confusables).
 - **Fail-safe isolation** (`safe_run`): a failing component degrades, it never blocks the pipeline.
 - **Untrusted-input caps** on body/attachment/HTML sizes.
 - **Credentials** live in git-ignored `creds/`; PBKDF2-hashed passwords in MongoDB.
-

14. Testing

- Framework: **pytest** (deterministic, no Docker/Mongo required); factory-built emails.
 - Coverage includes: contracts/`safe_run`, evidence ranking, parser, fusion registry, behavioral (10 scenarios), HTML (9), attachment (10), cross-modal (8), intent (8), uncertainty (6), shared tracking, MongoDB backend, pipeline integration.
 - Run: `pytest tests/ -q` (see `phishguard/README.md`).
-

15. Glossary

Term	Meaning
Evidence	A typed, ranked observation emitted by a detector
Component	A detector implementing <code>AnalysisComponent.run(...) → ComponentResult</code>
Fusion	Combiner of component features/evidence into a <code>Verdict</code>
REVIEW	High-risk + high-uncertainty level requiring human review
MAD	Median absolute deviation (robust spread)
Homoglyph	Visually confusable character (e.g. Cyrillic <code>а</code> vs Latin <code>a</code>)
MinHash / LSH	Probabilistic near-duplicate detection
Campaign	Cluster of structurally similar phishing messages
group_id	Campaign-aware split key preventing train/test

Term	Meaning
	leakage
Poisoning prevention	Not learning from (blocked) malicious mail
Calibration	Mapping raw scores to probabilities
Uncertainty	Estimate of component disagreement / missing signals

This reference describes the system as implemented in this repository. Some evaluation and adversarial components are specified in `extension_plan.md` and are being implemented incrementally.